# INCIDENT INVESTIGATION REPORT

**CyberDefenders Web Compromise Analysis**

**SEVERITY: CRITICAL**

> 📌 **Incident Overview:** This repository documents a forensic network investigation into a web server compromise at **BookWorld**, an online bookstore. Initiated following an anomalous spike in database queries and server resource utilization, Wireshark was utilized for packet analysis to dissect the attack lifecycle—from initial reconnaissance and SQL injection to credential theft and webshell deployment.

## 1. EXECUTIVE SUMMARY

**INCIDENT TYPE**
Web Application Attack / Automated SQLi & Webshell

**TARGET APPLICATION**
BookWorld Online Bookstore ( `bookworldstore.com` )

**LEAD SECURITY ANALYST**
Ahmed Raafat

**SERVER ENVIRONMENT**
Apache/2.4.52 (Ubuntu)

## 2. ATTACK CHAIN & VISUAL FORENSIC EVIDENCE

1. **Reconnaissance & Initial Access:** The threat actor probed the web application's search functionality ( `/search.php?search=` ) using automated scanning tools to identify vulnerability vectors.

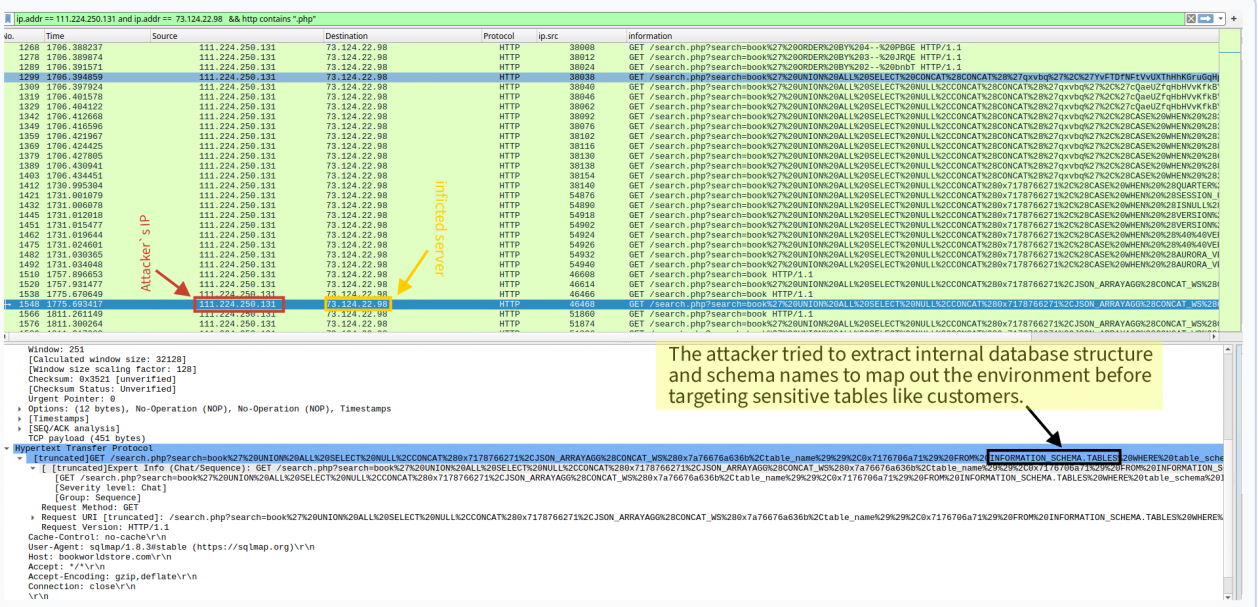



*Figure 1: HTTP traffic analysis capturing requests directed at search.php with explicit sqlmap User-Agent signature.*

2. **Exploitation (SQL Injection):** Execution of advanced SQL injection techniques, including Boolean-based ( `AND 1=1` , `AND 1=2` ), Time-based ( `PG_SLEEP(5)` ), Error-based ( `EXTRACTVALUE` , `XMLType` ), and UNION-based injections ( `UNION ALL SELECT` ).




```
GET /search.php?search=book%27%20UNION%20ALL%20SELECT%20NULL%2CCONCAT%280x7178766271%2CJSON_ARRAYAGG%28CONCAT_WS%280x7a76676a636b%2Ctable_name%29%29%2C0x7176706a71%29%20FRO
M%20INFORMATION_SCHEMA.TABLES%20WHERE%20table_schema%20IN%20%280x626f6f6b776f726c645f6462%29--%20- HTTP/1.1
Cache-Control: no-cache
User-Agent: sqlmap/1.8.3#stable (https://sqlmap.org)
Host: bookworldstore.com
Accept: */*
Accept-Encoding: gzip,deflate
Connection: close

HTTP/1.1 200 OK
Date: Fri, 15 Mar 2024 12:08:56 GMT
Server: Apache/2.4.52 (Ubuntu)
Vary: Accept-Encoding
Content-Encoding: gzip
Content-Length: 166
Connection: close
Content-Type: text/html; charset=UTF-8

<p>qxvbq["admin", "books", "customers"]qvpjq</p><form action="search.php" method="get">
    <input type="text" name="search" placeholder="Search for books...">
    <input type="submit" value="Search">
</form>
```

*Figure 2: Inspection of malicious query parameters revealing time-based and error-based functions alongside HTTP 500 error*

## 2. ATTACK CHAIN & VISUAL EVIDENCE (CONT.)

3. **Database Enumeration:** Extraction of internal database structures and sensitive schema data, specifically targeting customer information tables ( `customers` ).

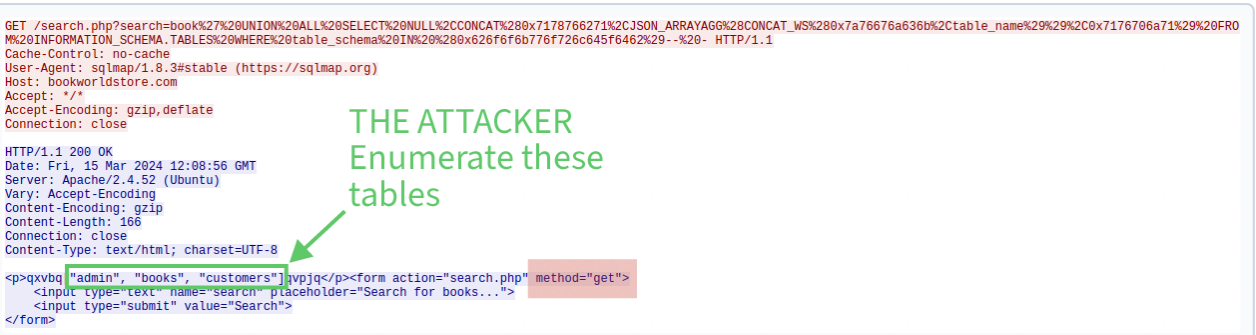



*Figure 3: Analysis of server responses during schema enumeration of the customers data table.*

4. **Credential Compromise & Post-Exploitation:** Accessing hidden administrative directories ( `/admin/` ) and authenticating with compromised credentials, culminating in the upload of a malicious PHP webshell ( `NVri2vhp.php` ) for persistent remote code execution.

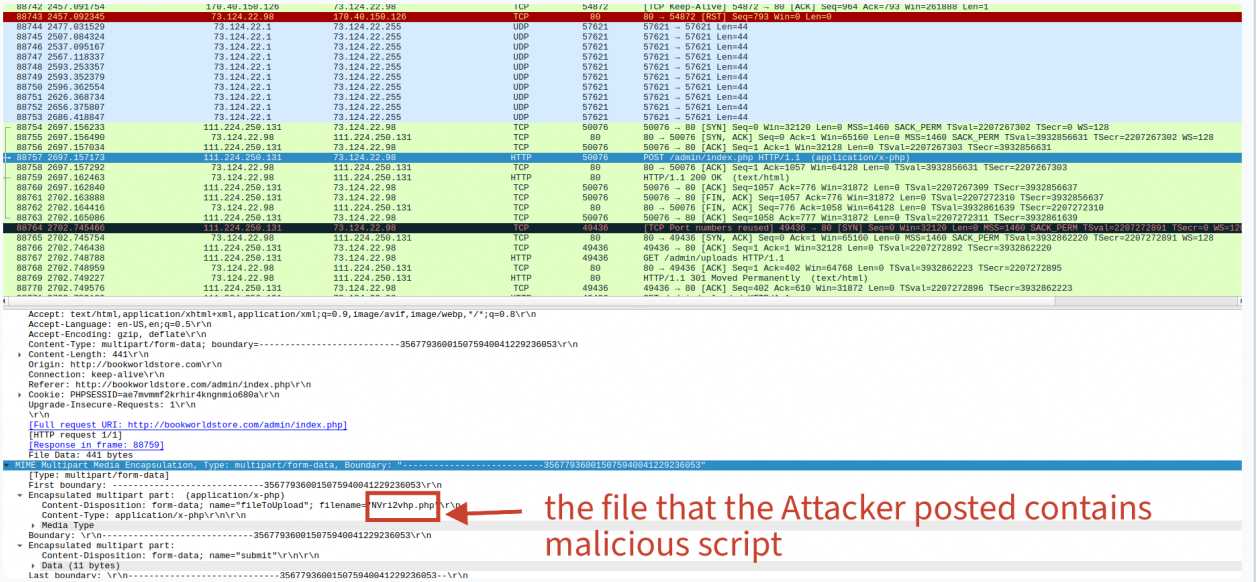



*Figure 4: Detection of the uploaded malicious script (NVri2vhp.php) on the underlying web server environment.*

## 3. INDICATORS OF COMPROMISE (IOCS)

| TYPE | INDICATOR / VALUE | DESCRIPTION |
|---|---|---|
| **Target Endpoint** | `http://bookworldstore.com/search.php?search=` | Vulnerable search parameter utilized for SQLi |
| **Tool User-Agent** | `sqlmap/1.8.3#stable` | Automated exploitation framework signature |
| **Attack Signatures** | `PG_SLEEP(5)` , `EXTRACTVALUE` , `UNION ALL SELECT` | Malicious SQL injection payloads observed in traffic |
| **Compromised Table** | `customers` | Database table containing sensitive website user records |
| **Hidden Directory** | `/admin/` | Unauthorized administrative path discovered and accessed |
| **Malicious File** | `NVri2vhp.php` | Uploaded PHP webshell for remote code execution |